

ANALISIS RISIKO KEAMANAN INFORMASI PADA WEBSITE PKM STMIK LOMBOK MENGGUNAKAN STANDAR ISO 27005:2022

Azka Ibad 1, Karan Maulana Syaputra 2, Zaldi Zofyan 3, Bq Rina Prihatiningsih 4, Nurani 5

Program Studi Teknik Informatika, STMIK Lombok

Email: kaa@mhs.ac.id, karan@mhs.ac.id, Zaldi@mhs.ac.id, Rina@mhs.ac.id, Rani@mhs.ac.id

Abstrak

(Bagian ini ditulis terakhir setelah seluruh laporan/jurnal selesai disusun. Isinya merupakan ringkasan komprehensif yang mencakup: Latar belakang singkat mengenai pentingnya pengelolaan risiko TI, tujuan utama penelitian untuk mengidentifikasi dan memigrasi risiko, metodologi atau framework manajemen risiko yang digunakan, hasil analisis tingkat risiko utama, serta kesimpulan akhir berupa rekomendasi kontrol keamanan. Ditulis dalam satu paragraf tunggal, maksimal 200–250 kata).

Kata Kunci: Manajemen Risiko TI, [Nama Metode/Framework], [Nama Aplikasi/Sistem].

1. Pendahuluan

Perkembangan teknologi informasi yang semakin pesat telah mendorong berbagai organisasi dan institusi pendidikan untuk memanfaatkan sistem informasi berbasis web dalam mendukung aktivitas operasional dan layanan kepada pengguna. Pemanfaatan teknologi informasi memberikan berbagai keuntungan, seperti kemudahan akses informasi, efisiensi pengelolaan data, serta peningkatan kualitas layanan. Dalam lingkungan perguruan tinggi, sistem informasi berbasis web telah menjadi sarana penting untuk mendukung berbagai kegiatan akademik maupun non-akademik, termasuk pengelolaan Program Kreativitas Mahasiswa (PKM). Keberadaan sistem yang dapat diakses secara daring memungkinkan proses administrasi, penyampaian informasi, dan pengelolaan dokumen dilakukan secara lebih efektif dan efisien. Pentingnya pengelolaan risiko pada sistem informasi digital juga semakin meningkat seiring bertambahnya ketergantungan organisasi terhadap teknologi informasi dalam menjalankan proses bisnis dan layanan publik (Chandra et al., 2022; Astini et al., 2024).

Website PKM STMIK Lombok merupakan salah satu sistem informasi yang digunakan untuk mendukung pelaksanaan kegiatan Program Kreativitas Mahasiswa. Melalui website tersebut, mahasiswa dapat memperoleh informasi terkait program PKM, melakukan pengunggahan dokumen proposal, serta berinteraksi dengan pengelola program secara lebih mudah. Ketergantungan pengguna terhadap website ini menjadikan aspek keamanan informasi sebagai salah satu faktor yang sangat penting dalam menjaga keberlangsungan layanan. Gangguan terhadap keamanan informasi tidak hanya berpotensi menghambat aktivitas pengguna, tetapi juga dapat menyebabkan kerugian bagi institusi akibat hilangnya data, terganggunya layanan, maupun menurunnya kepercayaan pengguna terhadap sistem yang digunakan.

Seiring meningkatnya penggunaan sistem berbasis web, ancaman dan risiko keamanan informasi juga semakin berkembang. Berbagai serangan siber seperti malware, phishing, SQL Injection, dan Cross Site Scripting (XSS) menjadi ancaman yang dapat memengaruhi

kerahasiaan, integritas, dan ketersediaan informasi. Selain itu, risiko operasional seperti kegagalan server (*server downtime*), kehilangan data akibat kegagalan sistem, lemahnya mekanisme autentikasi pengguna, serta kurang optimalnya proses pencadangan data (*backup*) juga dapat mengganggu operasional sistem. Risiko-risiko tersebut berpotensi menyebabkan kebocoran informasi, akses tidak sah terhadap data pengguna, kerusakan data, hingga terhentinya layanan yang berdampak langsung pada proses pengelolaan kegiatan PKM. Ancaman serupa juga ditemukan pada berbagai penelitian mengenai keamanan website dan sistem informasi yang menunjukkan bahwa risiko keamanan informasi masih menjadi salah satu tantangan utama dalam pengelolaan layanan berbasis web (Utami et al., 2023; Maulana & Mahardika, 2025).

Berdasarkan observasi awal terhadap Website PKM STMIK Lombok, terdapat beberapa potensi risiko yang perlu mendapatkan perhatian, antara lain risiko kebocoran data pengguna, kemungkinan terjadinya kegagalan layanan akibat gangguan server, penggunaan kata sandi yang lemah, ancaman malware melalui fitur unggah dokumen, risiko kehilangan data, serta kemungkinan eksploitasi celah keamanan aplikasi web seperti SQL Injection dan Cross Site Scripting (XSS). Apabila risiko-risiko tersebut tidak dikelola dengan baik, maka dapat mengganggu kinerja sistem dan menurunkan kualitas layanan yang diberikan kepada pengguna. Oleh karena itu, diperlukan suatu pendekatan yang sistematis untuk mengidentifikasi, menganalisis, dan mengevaluasi tingkat risiko yang terdapat pada website tersebut sehingga dapat diketahui risiko-risiko yang memerlukan prioritas penanganan. Pendekatan analisis risiko menggunakan ISO 27005 telah banyak digunakan untuk mengidentifikasi dan mengevaluasi risiko keamanan informasi pada berbagai sistem informasi karena mampu memberikan gambaran tingkat risiko secara terstruktur dan terukur (Isnaini et al., 2023; Astini et al., 2024).

Salah satu standar yang dapat digunakan untuk melakukan analisis risiko keamanan informasi adalah ISO/IEC 27005:2022. Standar ini menyediakan panduan dalam proses manajemen risiko keamanan informasi yang meliputi identifikasi aset, identifikasi ancaman dan kerentanan, analisis risiko, evaluasi risiko, serta penentuan perlakuan risiko (*risk treatment*). Penerapan standar ISO/IEC 27005:2022 memungkinkan organisasi untuk memahami kondisi keamanan sistem secara lebih terstruktur dan membantu dalam menentukan langkah mitigasi yang sesuai berdasarkan tingkat risiko yang ditemukan. Selain itu, standar ini juga masih relevan digunakan dalam pengelolaan risiko keamanan informasi modern karena mampu beradaptasi dengan berbagai jenis ancaman dan kebutuhan organisasi yang terus berkembang (Flores & Perugachi, 2023; Astini et al., 2024).

Berdasarkan uraian tersebut, penelitian ini dilakukan untuk menganalisis risiko keamanan informasi pada Website PKM STMIK Lombok menggunakan standar ISO/IEC 27005:2022. Penelitian ini bertujuan untuk mengidentifikasi aset informasi yang terdapat pada sistem, mengidentifikasi ancaman dan kerentanan yang berpotensi memengaruhi keamanan informasi, menganalisis tingkat kemungkinan dan dampak dari setiap risiko yang ditemukan, serta mengevaluasi tingkat risiko yang dimiliki oleh Website PKM STMIK Lombok. Hasil penelitian diharapkan dapat memberikan rekomendasi mitigasi yang tepat dan menjadi bahan pertimbangan bagi pengelola sistem dalam meningkatkan keamanan informasi serta menjaga keberlangsungan layanan Website PKM STMIK Lombok.

2. Tinjauan Pustaka / Landasan Teori

Bagian ini berisi dasar-dasar teori, konsep, standar, atau penelitian terdahulu yang dijadikan pijakan ilmiah dalam melakukan analisis manajemen risiko. Pastikan untuk selalu menyertakan sitasi atau sumber referensi yang valid pada setiap teori yang dikutip.

2.1 Manajemen Risiko Teknologi Informasi

Manajemen risiko teknologi informasi merupakan suatu proses yang dilakukan secara sistematis untuk mengidentifikasi, menganalisis, mengevaluasi, dan menangani risiko yang dapat memengaruhi aset informasi maupun operasional organisasi. Menurut ISO 31000:2018, manajemen risiko adalah aktivitas terkoordinasi yang digunakan untuk mengarahkan dan mengendalikan organisasi terkait risiko yang dihadapi. Penerapan manajemen risiko bertujuan untuk meminimalkan kemungkinan terjadinya ancaman serta mengurangi dampak yang ditimbulkan apabila risiko tersebut terjadi.

Dalam lingkungan teknologi informasi, risiko dapat berasal dari berbagai sumber, seperti kegagalan perangkat keras, kesalahan manusia (human error), serangan siber, kerusakan perangkat lunak, maupun bencana alam. Risiko-risiko tersebut dapat mengganggu ketersediaan layanan, menyebabkan kehilangan data, hingga menimbulkan kerugian bagi organisasi. Oleh karena itu, manajemen risiko menjadi salah satu komponen penting dalam tata kelola teknologi informasi guna menjaga keamanan dan keberlangsungan layanan sistem informasi (Chandra et al., 2022).

Keberhasilan proses manajemen risiko sangat dipengaruhi oleh penilaian terhadap tingkat kemungkinan (likelihood) dan dampak (impact) dari suatu risiko. Likelihood menunjukkan seberapa besar kemungkinan suatu ancaman terjadi, sedangkan impact menunjukkan tingkat kerugian yang ditimbulkan apabila ancaman tersebut benar-benar terjadi. Kombinasi kedua parameter tersebut digunakan untuk menentukan tingkat risiko (risk level) yang menjadi dasar dalam penentuan prioritas penanganan risiko (Astini et al., 2024).

-
- Selain itu, dalam konteks keamanan informasi, manajemen risiko berperan dalam menjaga tiga aspek utama keamanan informasi yaitu kerahasiaan (confidentiality), integritas (integrity), dan ketersediaan (availability). Ketiga aspek tersebut menjadi dasar dalam proses identifikasi dan evaluasi risiko keamanan informasi pada suatu sistem berbasis web.**Metode Analisis yang Digunakan:** Bedah secara mendetail kerangka kerja (framework) manajemen risiko yang kalian pilih. Jika menggunakan ISO 27005:2022, jabarkan tahapan pengujiannya (seperti System Characterization, Threat Identification, Vulnerability Identification, Control Analysis, Likelihood Determination, Impact Analysis, Risk Determination, dll.). Jika memilih OCTAVE Allegro, jelaskan fokusnya pada area aset informasi. Jika menggunakan ISO 27005, jelaskan dimensi kontrol keamanan informasi yang dianalisis.

3. Metodologi Penelitian

Gambarkan secara sistematis langkah-langkah prosedural yang ditempuh dalam mengidentifikasi aset, menganalisis ancaman, hingga menentukan tingkat risiko TI. Sangat

disarankan untuk menyisipkan diagram alir (flowchart) penelitian pada bagian ini agar pembaca mudah memahami struktur kerja kalian.

- **Tahapan Penelitian:** Sebutkan fase penelitian secara kronologis, mulai dari studi literatur awal, identifikasi aset TI dan penilaian kerentanan, proses pengumpulan data di lapangan/sistem, fase analisis perhitungan tingkat risiko (skor matriks risiko), hingga perumusan rekomendasi mitigasi dan penarikan kesimpulan akhir.
- **Teknik Pengumpulan Data:** Jelaskan instrumen pengumpulan data yang diaplikasikan. Apakah berupa metode Kuantitatif/Kualitatif (menyebarkan kuesioner berbasis skala Likert atau kuesioner tingkat kematangan kepada pengelola dan pengguna sistem), atau metode Eksperimental/Observasional (melakukan vulnerability scanning menggunakan tools tertentu, wawancara mendalam dengan tim IT, serta analisis dokumen SOP keamanan).
- **Populasi dan Sampel / Objek Penelitian:** Tentukan siapa target representatif yang menjadi subjek penelitian (tim IT, administrator, atau pengguna sistem) atau tentukan batasan aset TI yang dianalisis (hardware, software, data, atau sdm). Sebutkan total populasi/aset (jika diketahui) serta jumlah sampel atau ruang lingkup yang berhasil dikumpulkan beserta teknik samplingnya (misal: Purposive Sampling).

4. Hasil dan Pembahasan

Ini merupakan bagian paling krusial dari jurnal tempat data risiko mentah diolah, disajikan, dihitung tingkat keparahannya, dan diinterpretasikan. Sajikan data secara visual menggunakan tabel terstruktur atau grafik agar terlihat profesional dan mudah dipahami.

- **Karakteristik Aset dan Responden:** Paparkan profil demografi responden atau klasifikasi aset TI yang dianalisis (misalnya persentase tingkat kritikalitas aset, profil tim IT yang berpartisipasi, atau jenis-jenis ancaman dominan yang teridentifikasi pada sistem).
- **Hasil Analisis Risiko:** Tampilkan visualisasi nilai akhir, skor tingkat risiko (Risk Level Score), atau peta risiko (Risk Map Matrix) yang diperoleh dari hasil perkalian tingkat kemungkinan (Likelihood) dan tingkat dampak (Impact) pada tiap skenario risiko yang diuji.

No.	Skenario Risiko TI / Ancaman Keamanan	Skor Risiko / Level Risiko
1	Kegagalan Ketersediaan Sistem (Server Downtime akibat Overload)	Tinggi (High Risk)
2	Kerentanan Keamanan Data (Risiko Kebocoran Informasi Akun)	Sedang (Medium Risk)
3	Kurangnya Kesadaran Keamanan (User Menggunakan Password	Sedang (Medium Risk)

	Lemah)	
--	--------	--

- **Pembahasan:** Berikan kupasan tajam mengenai makna dari angka-angka hasil analisis risiko tersebut. Hubungkan fakta lapangan dengan landasan teori tata kelola atau manajemen risiko yang kalian tulis di Bab 2 serta bandingkan dengan riset terdahulu. Contoh: "Risiko Kegagalan Ketersediaan Sistem mendapatkan status Tinggi (High Risk), hal ini mengindikasikan bahwa infrastruktur server saat ini belum memiliki cadangan (redundancy) yang memadai jika lonjakan akses terjadi. Kerentanan ini memerlukan penanganan segera berupa penerapan load balancing dan rencana pemulihan bencana (Disaster Recovery Plan)."

5. Kesimpulan dan Saran

- **Kesimpulan:** Sajikan intisari jawaban atas rumusan masalah penelitian manajemen risiko. Tarik benang merah dari hasil analisis data untuk menentukan profil risiko total dari sistem yang diuji, serta sebutkan risiko apa saja yang paling kritis dan membutuhkan perhatian prioritas dari pihak manajemen organisasi.
- **Saran / Rekomendasi Mitigasi:** Berikan rekomendasi kontrol keamanan yang praktis, konkret, aplikatif, dan dapat diimplementasikan berdasarkan standar framework yang digunakan (misalnya tindakan perbaikan arsitektur server, pembuatan SOP pengelolaan backup, pelatihan awareness keamanan siber bagi staf, atau pemasangan firewall tambahan). Berikan juga masukan konstruktif bagi peneliti selanjutnya yang ingin memperluas scope riset ini (misalnya melanjutkan hingga tahap audit atau penyusunan dokumen keberlangsungan bisnis / BCP).

Daftar Pustaka (15 jurnal 5 tahun terakhir)

Astini, N. K. D., Putri, G. A. A., & Githa, D. P. (2024). Information technology risk analysis using ISO 27005:2022 at Diskominfo Tabanan Regency. *Jurnal Riset Informatika*, 7(4).

<https://doi.org/10.34288/jri.v7i4.394>

Chandra, N. A., Ramli, K., Putri, A. A. P. R., & Gunawan, T. S. (2022). Information security risk assessment using situational awareness frameworks and application tools. *Risks*, 10(8), 165.

<https://doi.org/10.3390/risks10080165>

Flores, D. A., & Perugachi, R. (2023). A GDPR-compliant risk management approach based on threat modelling and ISO 27005. *arXiv Preprint arXiv:2306.04783*.

<https://doi.org/10.48550/arXiv.2306.04783>

Isnaini, K., Sari, G. J. N., & Kuncoro, A. P. (2023). Analisis risiko keamanan informasi menggunakan ISO 27005:2019 pada aplikasi sistem pelayanan desa. *Eksplora Informatika*, 13(1). <https://doi.org/10.30864/eksplora.v13i1.696>

Maulana, R., & Mahardika, F. (2025). Analisis risiko keamanan pada sistem e-learning berdasarkan ISO 27005. *Jurnal Ilmiah Manajemen dan Teknologi (JIMT)*, 2(1).

<https://doi.org/10.71456/jimt.v2i1.1362>

Utami, G. C., Supramaji, A. B., & Isnaini, K. N. (2023). Penilaian risiko keamanan informasi pada website dengan metode DREAD dan ISO 27005:2018. *JUSTINDO (Jurnal Sistem dan Teknologi Informasi Indonesia)*, 8(1). <https://doi.org/10.32528/justindo.v8i1.219>

Tuliskan seluruh daftar referensi ilmiah (buku, jurnal, prosiding seminar, atau dokumen regulasi manajemen risiko TI resmi) yang kalian kutip di dalam naskah secara alfabetis. Format penulisan wajib menyesuaikan dengan standardisasi instruksi dosen pengampu (umumnya menggunakan standar APA Style 7th Edition atau IEEE Style).

Contoh format APA Style:

Nama Belakang, Inisial Penulis. (Tahun). Judul Artikel Jurnal. Nama Jurnal, Volume(Isu), Halaman.

Saran: Manfaatkan tools reference manager eksternal seperti Mendeley, Zotero, atau EndNote untuk mempermudah manajemen sitasi secara otomatis dan presisi.

Tips Strategis Pengerjaan Tugas Kelompok:	1. Pembagian Tugas per Bab:	2. Pemilihan Objek Penelitian yang Aksesibel:
Maksimalkan kolaborasi tim dengan efisien dan terarah.	Agar pengerjaan berjalan paralel, koordinasikan pembagian bab secara adil.	Pilihlah sistem informasi atau aplikasi yang sering digunakan dalam aktivitas sehari-hari

	Misal, Anggota A & B menyusun Pendahuluan & Tinjauan Pustaka; Anggota C berfokus mendesain instrumen, melakukan wawancara, atau melakukan scanning kerentanan (Metodologi); Anggota D & E melakukan rekapitulasi matriks risiko, kalkulasi skor dampak-kemungkinan, serta merumuskan Pembahasan risiko dan Kesimpulan.	serta memiliki risiko operasional yang nyata (seperti SIAKAD kampus, platform e-commerce, atau infrastruktur jaringan lokal). Hal ini akan sangat mempermudah kelompok dalam menghimpun data ancaman dan kerentanan serta mempercepat proses analisis risiko secara riil.
--	---	--